INFORME DE PRUEBAS DE PENETRACIÓN

Laboratorio «El Escriba»

Plataforma Whoami-Labs · Infra Dashboard (NODE-01)

Autor	**Josep Sanz**
Rol	Analista de seguridad ofensiva (Red Team)
Objetivo	172.17.0.2 · NODE-01 (PROD ENVIRONMENT)
Tipo de prueba	Caja negra (black-box) — red teaming guiado
Dificultad	Fácil · 1 XP
Fecha de la prueba	25 de octubre de 2026
Duración	34 minutos 22 segundos
Versión del informe	1.0
Clasificación	CONFIDENCIAL

Documento elaborado con fines educativos y de formación en un entorno de laboratorio autorizado. Ninguna acción descrita se ejecutó contra sistemas de terceros.

Aviso legal y confidencialidad

Autorización. Todas las pruebas documentadas en este informe se han realizado dentro del laboratorio aislado «El Escriba» de la plataforma Whoami-Labs, un entorno diseñado y autorizado explícitamente para la práctica de técnicas ofensivas. El objetivo (172.17.0.2) es una máquina de entrenamiento en una red interna de contenedores; no corresponde a ningún sistema de producción real ni a infraestructura de terceros.

Confidencialidad. Este documento tiene carácter CONFIDENCIAL. Reproduce credenciales, rutas de ataque e indicadores que, fuera de contexto, podrían facilitar un uso indebido. Su distribución debe limitarse a las personas con necesidad legítima de conocerlo.

Marco de referencia. La narrativa se estructura siguiendo las fases clásicas de un ejercicio de Red Team y se mapea, cuando procede, a tácticas del marco MITRE ATT&CK. Las puntuaciones de severidad son orientativas (estilo CVSS v3.1) y sirven para priorizar la remediación.

Índice

Aviso legal y confidencialidad 2
1. Resumen ejecutivo 4
2. Alcance y reglas de compromiso 5
2.1 Alcance (scope) 5
2.2 Reglas de compromiso (RoE) 5
3. Metodología 6
3.1 Herramientas utilizadas 6
4. Resumen de hallazgos 7
5. Desarrollo técnico del ataque 8
5.1 Fase 1 — Reconocimiento 8
5.2 Fase 2 — Enumeración web 8
5.3 Fase 3 — Análisis del código fuente y credenciales expuestas 9
5.4 Fase 4 — Acceso inicial 10
5.5 Fase 5 — Escalada de privilegios 11
5.6 Fase 6 — Compromiso total 12
6. Hallazgos detallados 14
7. Recomendaciones generales 20
8. Conclusión 21
9. Anexos 21

1. Resumen ejecutivo

Se ha llevado a cabo una prueba de penetración de caja negra sobre el host `172.17.0.2` (identificado internamente como NODE-01, un panel de monitorización de infraestructura). Partiendo únicamente de la dirección IP, se consiguió comprometer el sistema por completo y obtener privilegios de **root** en apenas 34 minutos.

El compromiso fue posible por una cadena de debilidades encadenadas, todas derivadas de malas prácticas de configuración y de gestión de secretos: credenciales incrustadas en el código fuente de la página web, reutilizadas para el acceso remoto por SSH, y una escalada de privilegios trivial a nivel local provocada por una capability de Linux mal asignada y una configuración de `sudo` excesivamente permisiva.

Resultado del ejercicio

Hito	Evidencia	Resultado
Acceso inicial (usuario de bajo privilegio)	`user.txt`	`Capabilities{e1_escriba_passwd}`
Compromiso total (control administrativo)	`root.txt`	`Capabilities{e1_escriba_v1m}`

Veredicto: el objetivo es **altamente vulnerable**. Cualquier atacante con conocimientos básicos podría replicar la toma de control completa. Se identificaron **tres hallazgos de severidad Crítica** y dos adicionales de severidad Alta e Informativa. La remediación es, afortunadamente, sencilla y de bajo coste (ver sección 7).

2. Alcance y reglas de compromiso

2.1 Alcance (scope)

Objetivo autorizado	`172.17.0.2 (NODE-01)`
Red	Red interna aislada de contenedores (laboratorio Whoami-Labs)
Fuera de alcance	Cualquier host distinto del objetivo; ataques de denegación de servicio; ingeniería social
Tipo de evaluación	Caja negra: sin credenciales ni información previa más allá de la IP
Ventana de pruebas	25/10/2026 — sesión única

2.2 Reglas de compromiso (RoE)

- La actividad se limita estrictamente al host en alcance.
- Se permiten enumeración, explotación de vulnerabilidades y escalada de privilegios.
- No se realizan acciones destructivas irreversibles sobre datos del laboratorio.
- Toda evidencia se documenta mediante capturas de pantalla fechadas.

3. Metodología

La prueba siguió una metodología por fases alineada con las etapas de una operación ofensiva real. Cada fase se corresponde con un objetivo táctico concreto:

Fase	Objetivo	MITRE ATT&CK
1. Reconocimiento	Descubrir hosts, puertos y servicios expuestos	TA0043 — Reconnaissance
2. Enumeración	Mapear la aplicación web y su contenido	TA0007 — Discovery
3. Análisis	Inspeccionar el código fuente en busca de secretos	T1552.001 — Credentials in Files
4. Acceso inicial	Obtener la primera sesión en el sistema	T1078 — Valid Accounts
5. Escalada	Pasar de usuario sin privilegios a root	T1548 — Abuse Elevation Control
6. Compromiso total	Confirmar control administrativo del host	T1078.003 — Local Accounts

3.1 Herramientas utilizadas

Herramienta	Uso en este ejercicio
`Nmap`	Descubrimiento de puertos y detección de servicios/versiones
`Feroxbuster`	Enumeración de contenido y directorios del servidor web
`cURL`	Descarga e inspección del código fuente HTML
`Base64 (decoder)`	Decodificación de las credenciales ofuscadas
`Cliente SSH (OpenSSH)`	Acceso remoto con las credenciales obtenidas
`getcap / find`	Enumeración de capabilities de ficheros del sistema
`vim.tiny`	Vector de escritura arbitraria para la escalada de privilegios

4. Resumen de hallazgos

La tabla siguiente resume las vulnerabilidades identificadas, ordenadas por severidad. El detalle técnico de cada una se encuentra en la sección 6.

ID	Hallazgo	Severidad	CVSS
F-01	Credenciales incrustadas en el código fuente de la aplicación web	Crítica	9.1
F-02	Capability cap_dac_override en /usr/bin/vim.tiny	Crítica	8.8
F-03	Configuración de sudoers excesivamente permisiva (NOPASSWD: ALL)	Crítica	8.4
F-04	Cuenta oculta con UID 0 y contraseña vacía («malicioso»)	Crítica	9.8
F-05	Reutilización de credenciales y contraseña débil	Alta	7.3
F-06	Divulgación de versiones de servicios	Informativa	2.9

Causa raíz. Aunque cada hallazgo es explotable por separado, todos comparten un patrón común: la exposición y la configuración negligente de credenciales y permisos. El comentario hallado en el propio código («*TODO: Move these variables to a secure vault before the Q4 audit*») confirma que el equipo era consciente del riesgo pero no lo había mitigado.

5. Desarrollo técnico del ataque

Esta sección reconstruye, paso a paso y con evidencias, la cadena completa desde el reconocimiento hasta el control total del host.

5.1 Fase 1 — Reconocimiento

Se inició con un escaneo completo de puertos TCP con detección de versiones y scripts por defecto sobre el objetivo:

```
nmap -p- -sV -sC -sS -n -Pn --min-rate=5000 172.17.0.2
```

El escaneo reveló dos servicios abiertos:

- `22/tcp` — OpenSSH 10.0p2 (Debian). Punto de acceso remoto potencial.
- `80/tcp` — Apache httpd 2.4.66, con título «Whoami-Labs | Infra Dashboard». Superficie de ataque web.

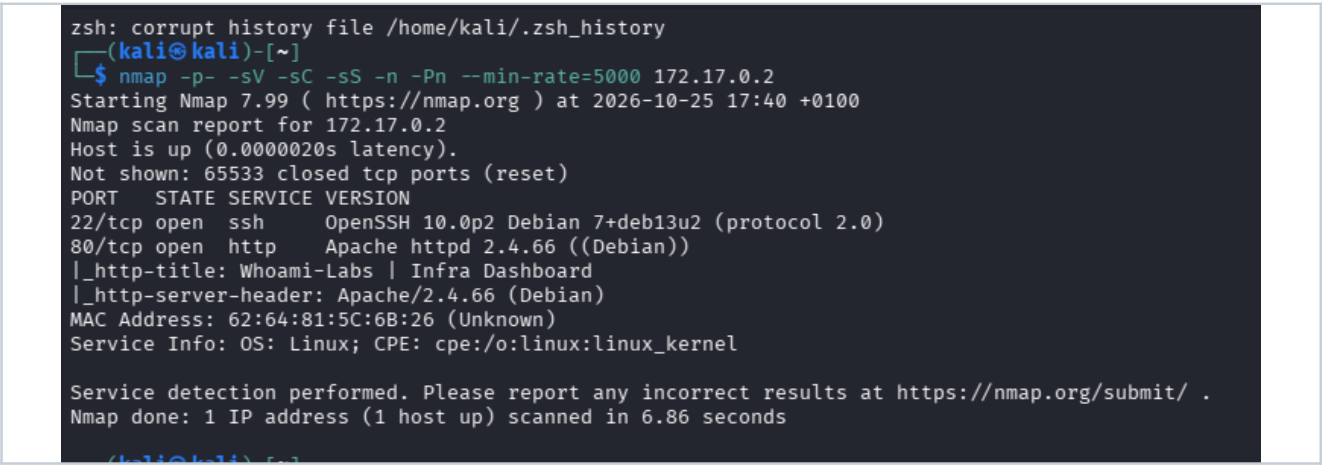


Figura 1 — Escaneo Nmap: puertos 22 (SSH) y 80 (HTTP) abiertos en el objetivo.

La coexistencia de un panel web y de SSH sugiere una vía clásica: localizar alguna credencial en la aplicación web y reutilizarla para autenticarse por SSH.

5.2 Fase 2 — Enumeración web

Se enumeró el contenido del servidor web con Feroxbuster, probando múltiples extensiones habituales:

```
feroxbuster -u http://172.17.0.2 -t 5 \
  -x php,bak,txt,html,py,zip \
  -w /usr/share/wordlists/seclists/Discovery/Web-Content/raft-medium-directories.txt
```

La aplicación es sencilla: responde con un `200 OK` en la raíz `/` y en `index.html`. No se halló contenido oculto adicional, lo que concentró la atención en la página principal.



Figura 2 — Enumeración con Feroxbuster: la superficie web se reduce a la página principal.

5.3 Fase 3 — Análisis del código fuente y credenciales expuestas

Se descargó el código fuente completo de la página con cURL para inspeccionarlo:

```
curl http://172.17.0.2
```

Dentro del HTML, un bloque de JavaScript etiquetado como «*INTERNAL API CONFIGURATION - DO NOT MODIFY*» contenía la configuración interna del nodo. Junto a un revelador comentario «*TODO: Move these variables to a secure vault before the Q4 audit*», aparecía un campo `legacy_auth` con un valor que, por su forma, es claramente una cadena Base64:

```
"legacy_auth": "c3R1ZGVudDpzdHVkZW50MTIz"
```



Figura 3 — El código fuente expone un token legacy_auth en el objeto de configuración interno.

Al decodificar la cadena Base64 se obtuvieron, en texto claro, un usuario y su contraseña:

```
echo c3R1ZGVudDpzdHVkZW50MTIz | base64 -d
student:student123
```

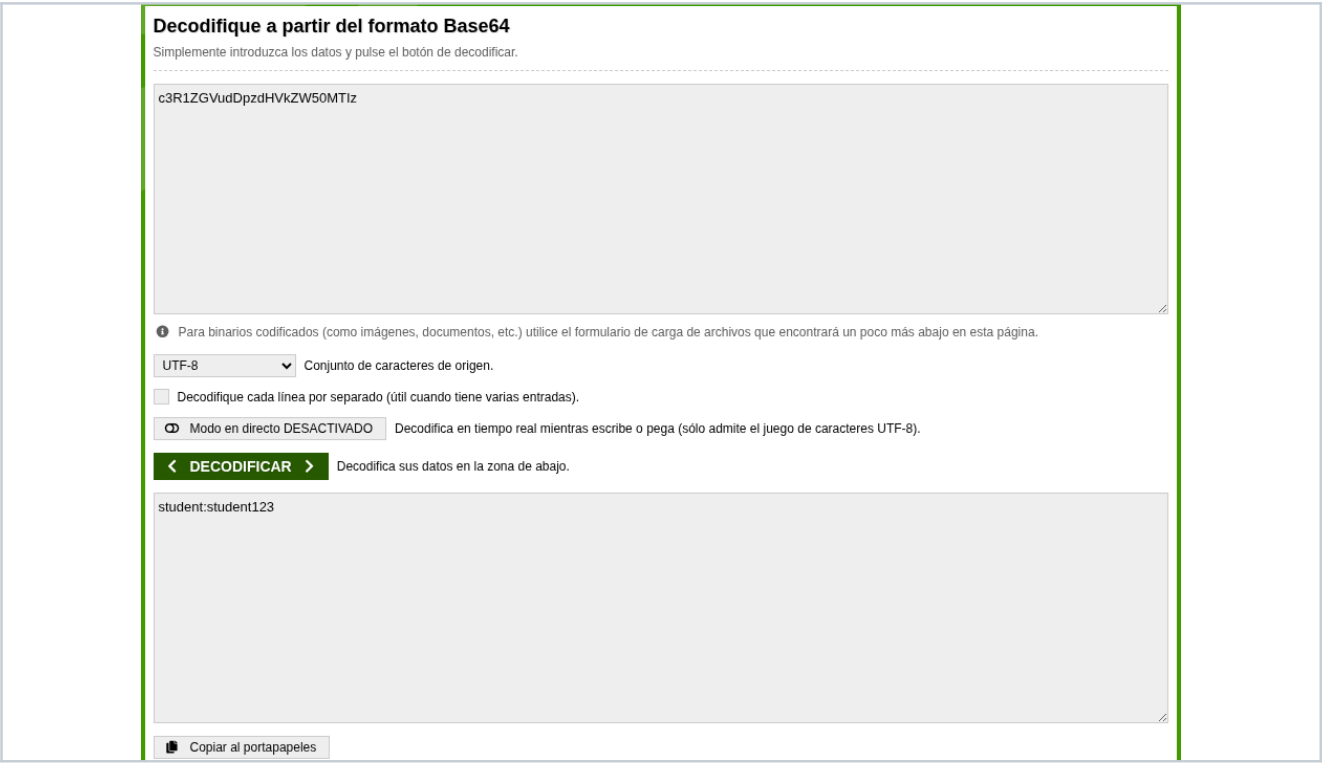


Figura 4 — Decodificación Base64: se revelan las credenciales student:student123.

Nota: Base64 **no es cifrado**; es una simple codificación reversible. Guardar credenciales así equivale a dejarlas en texto plano.

5.4 Fase 4 — Acceso inicial

Las credenciales obtenidas se probaron directamente contra el servicio SSH (puerto 22). El acceso fue inmediato:

```
ssh student@172.17.0.2
student@172.17.0.2's password: student123
```

Se obtuvo así una sesión interactiva como el usuario sin privilegios `student` (`uid=1000`).

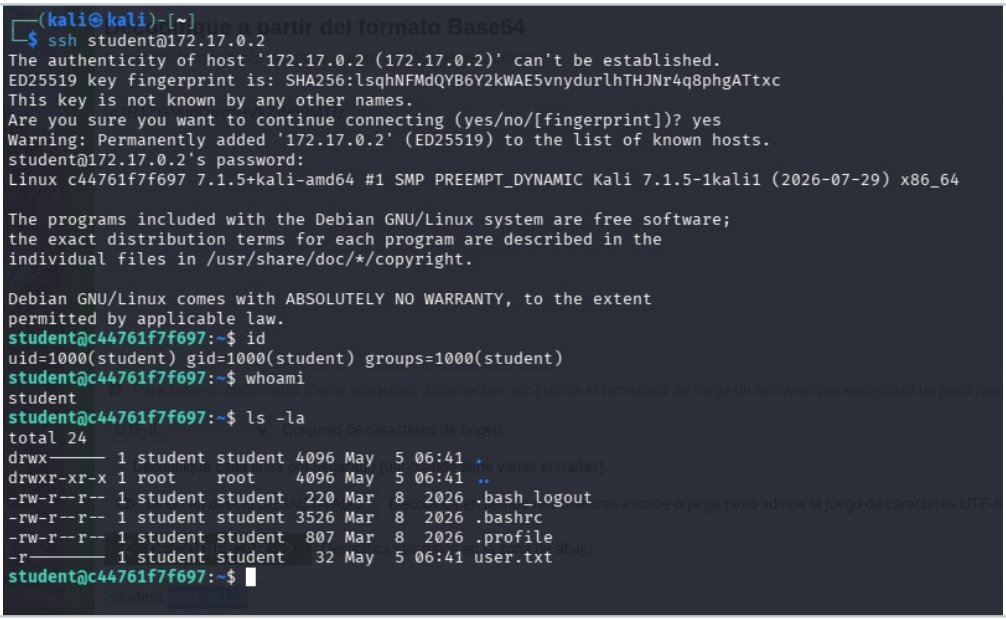


Figura 5 — Acceso inicial por SSH como el usuario student.

En el directorio personal del usuario se encontró la primera bandera, confirmando el acceso válido:

```
cat user.txt
Capabilities{e1_escriba_passwd}
```

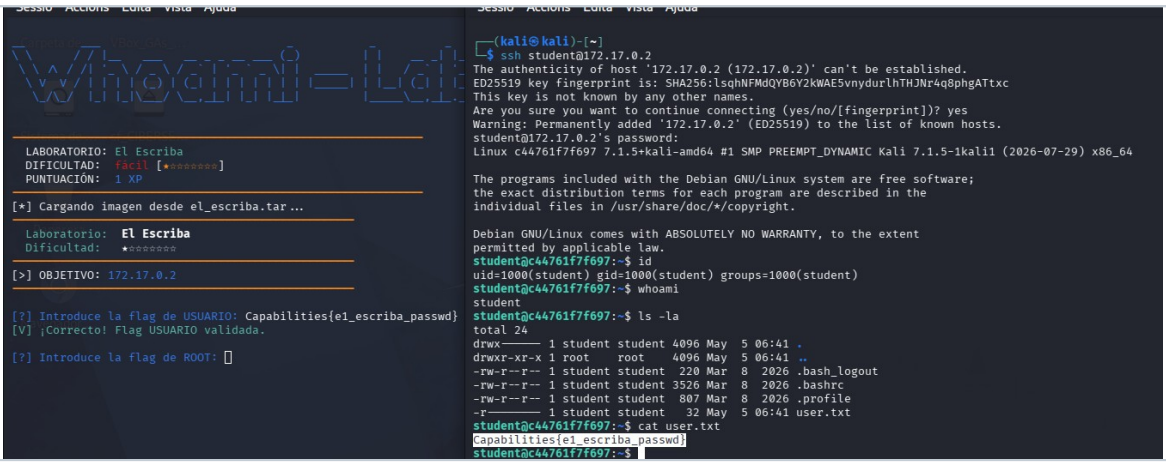


Figura 6 — Primera bandera obtenida (user.txt) y validada en la plataforma.

5.5 Fase 5 — Escalada de privilegios

Con acceso de bajo privilegio, el objetivo pasó a ser alcanzar root. Como es habitual tras obtener una shell, se enumeraron las **capabilities** de Linux asignadas a binarios del sistema. Las capabilities otorgan permisos concretos del superusuario a un programa individual, y una mala asignación es una vía directa de escalada:

```
getcap -r /
```

El resultado fue determinante: el editor `/usr/bin/vim.tiny` tiene asignada la capability `cap_dac_override=ep`.



Figura 7 — getcap revela cap_dac_override sobre /usr/bin/vim.tiny.

¿Por qué es crítico? `CAP_DAC_OVERRIDE` hace que el binario **ignore todas las comprobaciones de permisos de lectura y escritura** sobre los ficheros. Es decir, `vim.tiny` puede abrir y modificar **cualquier archivo del sistema** — incluidos los que solo root debería tocar— aunque lo ejecute un usuario normal. Esto convierte el editor en una primitiva de escritura arbitraria.

Esto permite editar directamente los ficheros más sensibles del sistema. Se inspeccionó `/etc/sudoers` y se comprobó que, además, la configuración de `sudo` era de por sí abusiva:

```
/usr/bin/vim.tiny /etc/sudoers
student ALL=(ALL:ALL) NOPASSWD: ALL
```

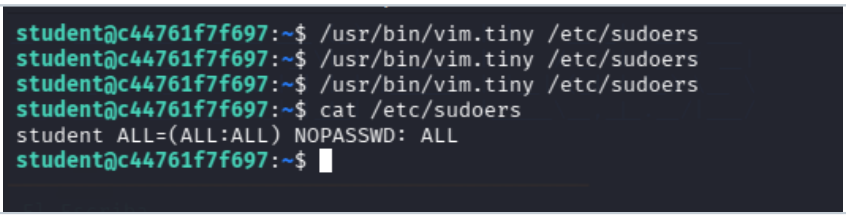


Figura 8 — El fichero sudoers concede a student todos los permisos sin contraseña.

Se dispuso así de **dos caminos independientes a root**. Para dejar constancia de la primitiva de escritura, se empleó `vim.tiny` en modo no interactivo para modificar `/etc/passwd` y neutralizar la contraseña de root (sustituyendo su hash por un campo vacío):

```
echo -e ':%s/^root:[^:]*:/root::/\nwq!' | /usr/bin/vim.tiny -es /etc/passwd
```

Al volcar `/etc/passwd` se confirmó el cambio: la línea de root quedó como `root::0:0:...` (sin contraseña). Se observó además la presencia de una **cuenta preexistente con UID 0 y contraseña vacía**: `malicioso::0:0:root:/root:/bin/bash` — una puerta trasera de facto con privilegios totales.

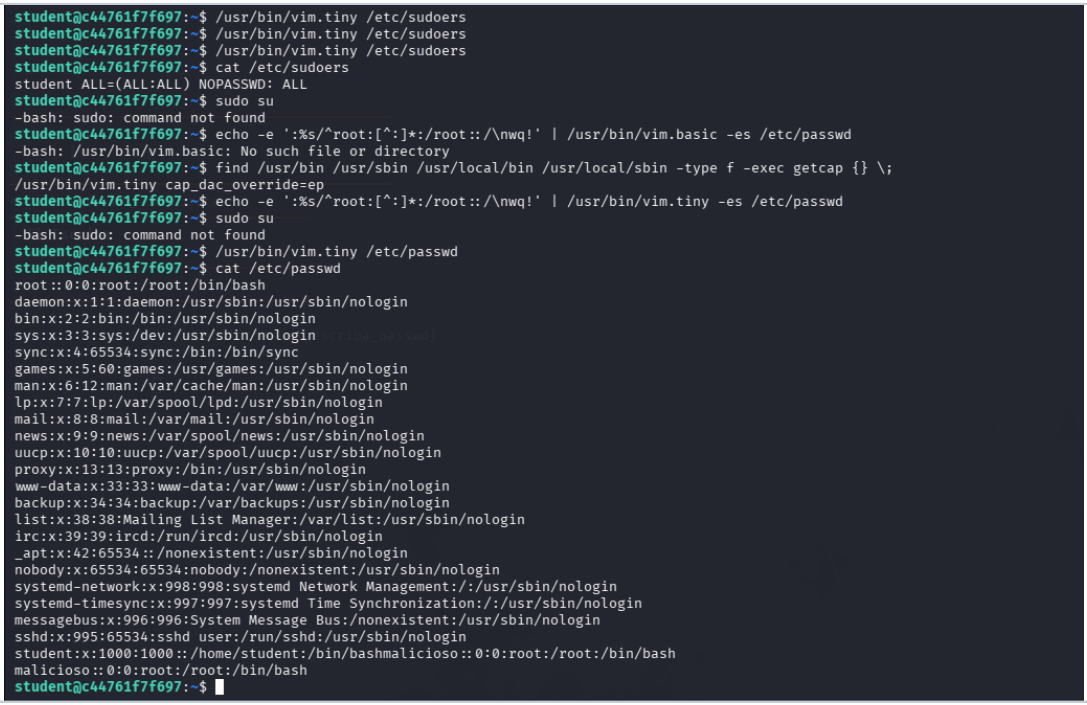


Figura 9 — /etc/passwd modificado: root sin contraseña y la cuenta «malicioso» con UID 0.

5.6 Fase 6 — Compromiso total

Con cualquiera de las cuentas de UID 0 ya accesibles sin contraseña, bastó un `su` para obtener una shell de root:

```
su malicioso
whoami   ->  root
id       ->  uid=0(root) gid=0(root) groups=0(root)
```

Confirmado el control administrativo, se recuperó la bandera final en el directorio de root:

```
cat /home/student/user.txt  ->  Capabilities{e1_escriba_passwd}
cat /root/root.txt          ->  Capabilities{e1_escriba_v1m}
```



Figura 10 — Shell de root obtenida, bandera final capturada y laboratorio completado (34m 22s).

Resultado: compromiso total del host. Se ha pasado de no tener ninguna información —solo una IP— a disponer de control administrativo completo, demostrando una cadena de ataque reproducible de principio a fin.

6. Hallazgos detallados

F-01	Credenciales incrustadas en el código fuente de la aplicación web	Crítica

Severidad	**Crítica**
CVSS v3.1 (orientativo)	**9.1 (Alto)**
Vector	`CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N`
MITRE ATT&CK	T1552.001 — Unsecured Credentials: Credentials In Files

Descripción

El código HTML/JavaScript servido públicamente por el puerto 80 contiene, en un objeto de configuración interno, un campo legacy_auth con credenciales codificadas en Base64. Base64 no ofrece ninguna protección: cualquier visitante puede descargar la página y decodificar el valor de forma trivial, obteniendo usuario y contraseña en texto claro.

Impacto

Un atacante no autenticado obtiene credenciales válidas del sistema con una sola petición HTTP. Combinado con el servicio SSH expuesto, esto se traduce directamente en acceso remoto al host (ver F-05).

Evidencia

Figuras 3 y 4. El valor "c3R1ZGVudDpzdHVkZW50MTIz" decodifica a "student:student123". El propio comentario del código («TODO: Move these variables to a secure vault...») evidencia que el riesgo era conocido.

Remediación

- Eliminar de inmediato cualquier credencial del código fuente, tanto del frontend como de repositorios.
- Gestionar los secretos en un almacén dedicado (HashiCorp Vault, AWS Secrets Manager, variables de entorno protegidas).
- Rotar las credenciales expuestas: deben considerarse comprometidas de forma permanente.
- Nunca confiar en Base64 como medida de protección; no es cifrado.
- Revisar el histórico del repositorio para purgar secretos ya versionados.

F-02	Capability cap_dac_override sobre /usr/bin/vim.tiny	Crítica

Severidad	**Crítica**
CVSS v3.1 (orientativo)	**8.8 (Alto)**
Vector	`CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H`
MITRE ATT&CK	T1548 — Abuse Elevation Control Mechanism

Descripción

El binario /usr/bin/vim.tiny tiene asignada la capability CAP_DAC_OVERRIDE. Esta capability desactiva las comprobaciones discrecionales de permisos (lectura/escritura) sobre los ficheros, de modo que el editor puede leer y escribir cualquier archivo del sistema con independencia de su propietario o permisos, incluso ejecutado por un usuario sin privilegios.

Impacto

Un usuario local con privilegios mínimos puede modificar archivos críticos del sistema (/etc/passwd, /etc/shadow, /etc/sudoers, etc.) y escalar a root. Es una primitiva de escritura arbitraria que conduce de forma fiable al compromiso total.

Evidencia

Figura 7 (getcap muestra "cap_dac_override=ep") y Figura 9 (edición efectiva de /etc/passwd para anular la contraseña de root).

Remediación

- Eliminar la capability del binario: setcap -r /usr/bin/vim.tiny.
- Auditar periódicamente todo el sistema con: getcap -r / (o find … -exec getcap).
- Aplicar el principio de mínimo privilegio: no conceder capabilities a editores ni intérpretes de uso general.
- Si se necesita acceso elevado puntual, canalizarlo mediante sudo con reglas específicas y registradas.

F-03	Configuración de sudoers excesivamente permisiva (NOPASSWD: ALL)	Crítica

Severidad	**Crítica**
CVSS v3.1 (orientativo)	**8.4 (Alto)**
Vector	`CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H`
MITRE ATT&CK	T1548.003 — Sudo and Sudo Caching

Descripción

El fichero /etc/sudoers contiene la regla "student ALL=(ALL:ALL) NOPASSWD: ALL", que permite al usuario student ejecutar cualquier comando como cualquier usuario (incluido root) sin necesidad de introducir contraseña.

Impacto

Cualquier sesión del usuario student equivale a acceso root instantáneo mediante "sudo su". Constituye una segunda vía, totalmente independiente de F-02, hacia el compromiso total.

Evidencia

Figura 8 (volcado de /etc/sudoers).

Remediación

- Retirar la regla NOPASSWD: ALL para cuentas de usuario estándar.
- Conceder, si es imprescindible, únicamente los comandos concretos que el usuario necesite.
- Exigir contraseña para las acciones privilegiadas y habilitar el registro de sudo (auditoría).
- Revisar también los ficheros incluidos bajo /etc/sudoers.d/.

F-04	Cuenta oculta con UID 0 y contraseña vacía («malicioso»)	Crítica

Severidad	**Crítica**
CVSS v3.1 (orientativo)	**9.8 (Crítico)**
Vector	`CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H`
MITRE ATT&CK	T1136.001 / T1078.003 — Create/Valid Local Accounts

Descripción

En /etc/passwd existe la cuenta "malicioso::0:0:root:/root:/bin/bash": un segundo usuario con UID 0 (privilegios de root) y con el campo de contraseña vacío. Se comporta como una puerta trasera: concede acceso administrativo a quien la use y pasa desapercibida frente a controles que solo vigilan la cuenta "root".

Impacto

Acceso root persistente y encubierto. Si el servicio de autenticación lo permitiera, la contraseña vacía habilitaría incluso acceso remoto directo. Es el mecanismo de persistencia utilizado para obtener la shell final.

Evidencia

Figura 9 (línea "malicioso::0:0:root:/root:/bin/bash" en /etc/passwd) y Figura 10 ("su malicioso" devuelve una shell de root).

Remediación

- Eliminar la cuenta de inmediato: userdel malicioso.
- Verificar que no existan otras cuentas con UID 0: awk -F: '$3==0' /etc/passwd.
- Prohibir cuentas con contraseña vacía (política de autenticación / PAM).
- Investigar el origen de la cuenta: su mera existencia sugiere un compromiso previo.
- Monitorizar cambios en /etc/passwd y /etc/shadow (p. ej., con auditd).

F-05	Reutilización de credenciales y contraseña débil	Alta

Severidad	**Alta**
CVSS v3.1 (orientativo)	**7.3 (Alto)**
Vector	`CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:L`
MITRE ATT&CK	T1078 — Valid Accounts

Descripción

Las mismas credenciales presentes en la web (student:student123) son válidas para el acceso por SSH. Además, la contraseña es débil y predecible (nombre de usuario + patrón numérico trivial), susceptible de descubrirse incluso por fuerza bruta o diccionario.

Impacto

La reutilización elimina cualquier barrera entre la exposición en la web y el acceso al sistema operativo. Una única fuga concede acceso interactivo al host.

Evidencia

Figura 5 (autenticación SSH exitosa con las credenciales de la web).

Remediación

- Usar credenciales distintas e independientes para cada servicio.
- Aplicar una política de contraseñas robusta (longitud, complejidad, no reutilización).
- Preferir autenticación SSH por clave pública y deshabilitar el acceso por contraseña.
- Implantar segundo factor (MFA) y bloqueo tras intentos fallidos (fail2ban).

F-06 Divulgación de versiones de servicios — Informativa

Severidad	**Informativa**
CVSS v3.1 (orientativo)	**2.9 (Bajo)**
Vector	`CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N`
MITRE ATT&CK	T1592 — Gather Victim Host Information

Descripción

Los servicios anuncian sus versiones exactas en los banners (OpenSSH 10.0p2, Apache 2.4.66). Esta información facilita a un atacante la búsqueda de exploits específicos para esas versiones.

Impacto

Por sí sola no compromete el sistema, pero reduce el esfuerzo de reconocimiento del atacante y amplía la superficie de ataque conocida.

Evidencia

Figura 1 (salida de Nmap con versiones detalladas).

Remediación

- Reducir la verbosidad de los banners cuando sea posible (p. ej., ServerTokens Prod en Apache).
- Mantener los servicios actualizados con los últimos parches de seguridad.
- Asumir que la versión es conocida y priorizar siempre el parcheado.

7. Recomendaciones generales

Acciones inmediatas (prioridad máxima)

1. **Eliminar la cuenta «malicioso»** y cualquier otra cuenta con UID 0 distinta de root (F-04).
2. **Retirar las credenciales del código web** y rotarlas; moverlas a un gestor de secretos (F-01).
3. **Quitar la capability** `cap_dac_override` de vim.tiny (F-02).
4. **Corregir sudoers:** eliminar la regla NOPASSWD: ALL (F-03).

Mejoras estructurales (medio plazo)

- Adoptar el principio de mínimo privilegio en usuarios, capabilities y reglas de sudo.
- Implantar gestión centralizada de secretos y prohibir su versionado en código.
- Migrar SSH a autenticación por clave y deshabilitar el login por contraseña; añadir MFA.
- Desplegar monitorización de integridad sobre /etc/passwd, /etc/shadow y /etc/sudoers (auditd).
- Realizar auditorías periódicas de capabilities, binarios SUID y cuentas con UID 0.
- Integrar revisión de secretos (secret scanning) en el ciclo de desarrollo (CI/CD).

8. Conclusión

El laboratorio «El Escriba» ilustra con claridad cómo una suma de pequeños descuidos de configuración —ninguno exótico— se encadena para producir un compromiso total del sistema. El patrón es el habitual en entornos reales: un secreto expuesto donde no debería, reutilizado donde no debería, y un sistema que, una vez dentro, ofrece múltiples atajos hacia root por permisos mal otorgados.

La buena noticia es que todas las causas son conocidas y de remediación sencilla. Aplicar el principio de mínimo privilegio, gestionar los secretos adecuadamente y auditar permisos y cuentas de forma periódica habría bloqueado la cadena en varios puntos distintos. La **defensa en profundidad** no consiste en una sola barrera infranqueable, sino en que ninguna debilidad aislada baste para perderlo todo.

Se recomienda remediar los hallazgos Críticos con carácter inmediato y abordar las mejoras estructurales como parte del ciclo normal de endurecimiento (hardening) del sistema.

9. Anexos

A. Banderas (flags) capturadas

Fichero	Bandera	Nivel
`/home/student/user.txt`	`Capabilities{e1_escriba_passwd}`	Usuario
`/root/root.txt`	`Capabilities{e1_escriba_v1m}`	Root

B. Cronología del ataque

#	Acción	Resultado
1	Escaneo Nmap del objetivo	Puertos 22 (SSH) y 80 (HTTP) abiertos
2	Enumeración web con Feroxbuster	Superficie limitada a index.html
3	Inspección del código fuente (cURL)	Hallado token legacy_auth en Base64
4	Decodificación Base64	Credenciales student:student123
5	Acceso por SSH	Shell como usuario student (uid 1000)
6	Lectura de user.txt	Primera bandera obtenida
7	Enumeración de capabilities (getcap)	cap_dac_override en vim.tiny
8	Revisión de /etc/sudoers	NOPASSWD: ALL para student
9	Edición de /etc/passwd con vim.tiny	Contraseña de root anulada
10	su a cuenta UID 0	Shell de root
11	Lectura de root.txt	Bandera final — compromiso total

Fin del informe

Elaborado por Josep Sanz · Laboratorio «El Escriba» · 25/10/2026